49,165	2,609,249	116	4	0
ALERTS PROCESSED	ZEEK RECORDS MATCHED	PCAPS ANALYZED	FINDINGS	EVIDENC

Claude Opus 4.6 Report

Do

Generated by Claude Opus 4.6 (CommonStack AI)

[Client Name] Network Security Incident Report

Generated: 2025-03-12 18:00:00 UTC

Executive Summary

Between March 1, 2025, and March 9, 2025, the organization's network was compromised by the Lynx ransomware group. The threat actor gained initial access by brute-forcing credentials for an externally exposed Remote Desktop Protocol (RDP) service on a server named `jjjjjjjRDP02`. Once inside, the attacker moved laterally across the network, escalating privileges and conducting extensive reconnaissance of the Active Directory environment. This reconnaissance culminated in a large-scale data theft operation on March 6, where over 1 GB of highly sensitive data—including personally identifiable information (PII), financial records, law enforcement files, and system backups—was exfiltrated to an external file-sharing service.

The business impact of this incident is severe, representing a "double extortion" scenario where the attacker has both encrypted critical systems and stolen sensitive data, creating significant operational, financial, legal, and reputational risk. The exfiltrated data includes employee and citizen PII (Social Security Numbers, dates of birth), credit card information (including CVVs), confidential law enforcement records, and critical infrastructure plans. Furthermore, the theft of domain controller backups provides the attacker with the means to forge credentials and maintain persistent access. Following the data theft, the attacker deployed ransomware across numerous servers, including file servers and backup systems, causing widespread service disruption.

Immediate action is required to contain the threat and mitigate further damage. The highest priorities are to reset all user and service account credentials across the enterprise, completely remove direct internet access to RDP services, and block the attacker's exfiltration infrastructure at the network perimeter. Concurrently, a full-scale recovery effort must begin, leveraging offline backups and engaging legal counsel to manage data breach notification obligations. This report provides a detailed technical analysis of the attack lifecycle, a complete list of compromised systems and data, and a prioritized set of recommendations to guide remediation and strategic security improvements.

Scope and Analytical Limitations

This report is based exclusively on the analysis of network traffic data captured from a core-switch tap over a nine-day

- **PCAP-derived Data:** Curated datasets from the full packet capture, providing ground-truth information on TCP conversations and specific protocol interactions that may have exceeded Zeek logging limits.

The analysis is therefore limited to activities that generate network traffic. While network forensics can definitively trace attacker communications, lateral movement, and data transfers between hosts, it has inherent limitations. Specifically, network evidence **CANNOT** show:

- **Local Host Activity:** Processes executed directly on a compromised host's console, local account creation or modification performed via the GUI, clipboard contents, or keystrokes entered during an interactive RDP session.
- **File System Interaction:** While we can observe a file being transferred via SMB, we cannot confirm its subsequent execution, modification, or deletion on the destination host's local disk without endpoint logs.
- **Local Credential Dumping:** Techniques like Mimikatz that dump credentials from a host's memory (e.g., LSASS process) are invisible to network monitoring unless the extracted credentials are immediately used in network authentication events.

Key analytical gaps and caveats include:

- **Zeek Log Capping:** Several Zeek log tables, notably `zeek_rdp` and `zeek_dce_rpc`, reached their configured row limits. This resulted in the omission of some attacker activity from these logs, which was instead identified through manual analysis of the full PCAP data.
- **TLS 1.3 Encryption:** The attacker used TLS version 1.3 for the data exfiltration phase. This strong encryption prevents any inspection of the contents of the uploaded files, meaning our analysis confirms the volume and staging of data but not the exact files included in each upload session.
- **Non-Standard Timestamps:** Certain PCAP-derived datasets used non-standard epoch timestamps, requiring careful correlation with Zeek's ISO 8601 formatted timestamps during pre-analysis.

A. Initial Access (Patient Zero)

The initial intrusion vector was confirmed as External Remote Access (MITRE T1133) via a publicly exposed RDP service. The attacker successfully brute-forced credentials for the domain account `lgallegos` to gain a foothold on the host `10.128.239.57` (jjjjjjjRDP02).

A.1 Pre-Intrusion Reconnaissance and Probing

A.1.1 External Reconnaissance Activity

Prior to the successful intrusion, the target host `10.128.239.57` was subjected to a large-scale, indiscriminate RDP credential spraying campaign. This activity, characteristic of automated scanning infrastructure, is considered background noise and is distinct from the targeted attack that followed.

- **Total Attempts:** 52,911 RDP connection attempts were observed against `10.128.239.57`.
- **Source IPs:** The spray originated from 170 unique external IP addresses.
- **Time Window:** The campaign spanned over 5 hours, from **2025-03-01T18:20:01Z** to **2025-03-01T23:25:36Z**.
- **Top Sources:** The most active scanners included `179.60.146.36` (1,578 attempts), `141.98.83.10` (1,314 attempts), and `194.0.234.17` (1,246 attempts using hundreds of usernames, indicative of dictionary stuffing). This activity filled the `zeek_rdp` log table, which capped at 10,000 rows.

A.1.2 Credential Testing and Validation

The actual attacker, using IP address `195.211.190.189`, was distinguished from the background spray by its low connection volume and immediate post-connection domain authentication activity. This IP was not present in the capped `zeek_rdp` logs but was identified in the full PCAP data. The timeline confirms a direct cause-and-effect sequence:

1. **RDP Connection Established:** At **2025-03-01T23:25:07.989Z**, the attacker IP `195.211.190.189` (AS214943 Railnet

`10.128.239.57` issued a Kerberos AS-REQ to the domain controller `10.128.239.23` for the client `lgallegos`. This request for a Ticket Granting Ticket (TGT) for the `WATER.domain-ees3Ai.LOCAL` domain confirms the attacker had successfully authenticated and was beginning to interact with Active Directory.

This tight temporal correlation between the RDP cookie and the Kerberos request provides high-confidence proof that `195.211.190.189` was the successful intruder and `lgallegos` was the compromised credential.

A.1.3 Suricata Detection Context

During the initial access phase, Suricata generated 161,663 alerts. While many were related to the RDP spray, several key alerts corroborate the attacker's activity. On March 6 and 8, the attacker IPs `195.211.190.189` and `77.90.153.30` triggered `ET DROP Spamhaus DROP Listed Traffic Inbound` alerts when they returned to access the patient zero host, confirming their known malicious reputation.

A.2 IOC Table

TYPE	VALUE	CONTEXT
Attacker IP	`195.211.190.189`	Initial access IP (AS214943 Railnet LLC).
Attacker IP	`77.90.153.30`	Second IP used for return access on March 8-9.
Credential	`lgallegos`	Domain user account compromised via RDP brute-force.
Patient Zero	`10.128.239.57`	Hostname `jjjjjjjRDP02`. Externally exposed RDP server.
Domain	`WATER.domain-ees3Ai.LOCAL`	The primary domain compromised during initial access.

A.3 Initial Access Timeline

TIMESTAMP	EVENT	SOURCE → DESTINATION	PROTOCOL	EVIDENCE SOURCE
2025-03-01T18:20:01.283Z	RDP credential spray begins	`179.60.146.36` → `10.128.239.57`	RDP	`zeek_rdp`
2025-03-01T23:25:07.989Z	Attacker establishes RDP session	`195.211.190.189` → `10.128.239.57`	RDP	`pcap_rdp`
2025-03-01T23:25:36.515Z	Attacker presents compromised credential	`195.211.190.189` → `10.128.239.57`	RDP	`pcap_rdp`
2025-03-01T23:25:43.484Z	Successful domain authentication	`10.128.239.57` → `10.128.239.23`	Kerberos	`zeek_kerberos`
2025-03-01T23:25:43.590Z	AD enumeration begins (account lookup)	`10.128.239.57` → `10.128.239.29`	DCERPC	`zeek_dce_rpc`
2025-03-01T23:25:44.172Z	AD enumeration via replication service	`10.128.239.57` → `10.128.239.23`	DCERPC	`zeek_dce_rpc`
2025-03-02T00:20:11.897Z	First lateral RDP pivot	`10.128.239.57` → `10.128.239.64`	RDP	`zeek_rdp`

B. Lateral Movement and Discovery

B.1 Overview

B.2.1 Discovery Waves and Scale

The attacker conducted three distinct waves of SMB write-access testing using a file named `delete.me`. This technique allowed them to map which hosts were accessible and writable from their compromised context, serving as a precursor to ransomware deployment.

- **Wave 1 (2025-03-01):** Starting at `23:30:37.580Z`, this wave consisted of **449** file operations targeting **133** unique hosts.
- **Wave 2 (2025-03-06):** Starting at `22:50:28.096Z`, this wave expanded to **526** file operations across **134** unique hosts.
- **Wave 3 (2025-03-08):** Starting at `08:22:04.126Z`, this final pre-deployment wave involved **504** file operations across **131** unique hosts.

In total, 1,479 `delete.me` operations were observed against 135 unique hosts.

B.2.2 Active Directory and Directory Enumeration

The attacker performed massive-scale enumeration of Active Directory using the Security Account Manager Remote Protocol (SAMR) and other DCERPC interfaces, primarily targeting domain controllers `10.128.239.23` and `10.128.239.29`.

- **SAMR Operations:**
- `SamrLookupDomainInSamServer`: **261** operations against 130 hosts to resolve domain names.
- `SamrOpenGroup`: **155** operations to open handles to specific domain groups.
- `SamrGetMembersInGroup`: **92** operations to enumerate members of groups like "Domain Admins".
- **Authentication Validation:** A staggering **240,175** `NetrLogonSamLogonEx` operations were recorded (236,198 to DC `.29` and 3,977 to DC `.23`), indicating widespread attempts to validate credentials or enumerate accounts.
- **Share Enumeration: 274** `NetrShareEnum` operations were performed against 106 hosts to map all available network shares.
- **DPAPI Credential Theft:** At **2025-03-06T22:41:51.038Z**, the attacker executed a `bkrp_BackupKey` call from `10.128.239.57` to DC `10.128.239.23` via the `\pipe\lsass` endpoint. This is a critical event, as it steals the domain's DPAPI backup key, enabling offline decryption of all domain users' stored credentials.
- **DCSync Probing:** 8 calls to the DRSUAPI interface (e.g., `DsBind`, `DsCrackNames`) were observed against DCs `.23` and `.29` starting at `2025-03-01T23:25:44Z`, indicating reconnaissance for a potential DCSync attack to replicate directory secrets.

B.2.3 RDP Port Scanning

On March 8, a fast RDP port scan was launched from the staging host `10.128.239.57`. Analysis of the raw PCAP revealed **514** TCP SYN packets sent to port 3389 across **153** unique internal hosts, mapping all systems potentially accessible via RDP for the final deployment phase.

B.2.4 Cross-Domain Infrastructure Mapping

The attacker successfully mapped the complex, multi-domain AD forest. SYSVOL shares on domain controllers `jjjjjjjwtDC23.water.domain-ees3Ai.local` (`10.128.239.29`) and `jjjjjjjwtDC8` (`10.128.239.23`) were accessed as early as `2025-03-01T18:24:08.333Z` to enumerate Group Policies. The discovery campaign identified nine domain controllers across six distinct domains:

- **ROOT:** `10.128.239.20`, `.21`
- **ADMIN:** `10.128.239.22`, `.27` (`jjjjjjjaddc7`)
- **POWER:** `10.128.239.28`
- **WATER:** `10.128.239.23` (`jjjjjjjwtDC8`), `.29` (`jjjjjjjwtDC23`)
- **PARKS:** `10.128.239.30` (`jjjjjjjpkdc2`)
- **SAFETY:** `10.128.239.31` (`jjjjjjjsfdc9`)

- `\\10.128.239.29\ADMIN$` (WATER DC)
- `\\10.128.239.23\ADMIN$` (WATER DC)
- `\\10.128.239.28\ADMIN$` (POWER DC)
- `\\10.128.239.30\ADMIN$` (PARKS DC)

B.3.2 Movement into Domain Infrastructure

The attacker demonstrated the ability to move between domains. On deployment day (March 9), an RDP session to host `10.128.239.39` used the cookie `SAFETY\IT`, confirming the use of a compromised credential from the `SAFETY` domain to access resources. Access to `ADMIN$` shares on DCs from different domains further confirms cross-domain compromise.

B.3.3 Interactive RDP Sessions

The attacker used RDP extensively for hands-on lateral movement. The first internal pivot occurred at **2025-03-02T00:20:11.897Z** from the patient zero host `10.128.239.57` to `10.128.239.64` using the `lgallegos` credential. In total, the attacker pivoted to **41** unique internal hosts via RDP. On March 9, interactive RDP sessions were used to manually deploy ransomware on at least 6 key file servers, including `.35`, `.36`, `.37`, `.39`, and `.176`.

B.4 MITRE ATT&CK Mapping

TECHNIQUE ID	SUB-TECHNIQUE	NAME	EVIDENCE
T1046	Network Service Discovery	RDP port scan of 153 internal hosts.	
T1021	T1021.002	SMB/Windows Admin Shares	Access to ADMIN$ on 62 hosts and C$ on 43 hosts.
T1003	T1003.006	DCSync	Probing of DRSUAPI interface on domain controllers.
T1003	OS Credential Dumping	`bkrp_BackupKey` call to steal domain DPAPI backup key.	
T1087	T1087.002	Domain Account	SAMR enumeration of domain users and groups.
T1069	T1069.002	Domain Groups	`SamrGetMembersInGroup` calls to enumerate group memberships.
T1135	Network Share Discovery	274 `NetrShareEnum` operations to map network shares.	
T1018	Remote System Discovery	`delete.me` testing across 135 unique hosts.	
T1021	T1021.003	Distributed Component Object Model	DCOM `RemoteCreateInstance` calls to `10.128.239.32`.

C. Data Exfiltration (Double Extortion)

C.1 Overview

On **2025-03-06**, the Lynx group executed a large-scale data exfiltration event. Data was staged from multiple internal servers to the compromised host `10.128.239.57`, which then uploaded it to an external destination. The total volume of

automated scripts. DNS records resolved `temp.sh` to the IP address **`51.91.79.17`**, which is hosted by OVH SAS (AS16276) in France.

C.3 DNS Resolution Evidence

Network logs confirm the attacker's use of the `temp.sh` service.

- **Query Count:** A total of **47** DNS queries for `temp.sh` were observed originating from the staging host `10.128.239.57`.
- **Time Window:** The queries occurred between **2025-03-06T23:40:59.105Z** and **2025-03-06T23:42:18.480Z**.
- **Resolved IP:** All queries successfully resolved `temp.sh` to `51.91.79.17`.

C.4 TLS Connection Evidence

Analysis of the packet capture confirms encrypted connections were established to the exfiltration server.

- **Session Count:** **11** distinct TLS sessions were initiated from `10.128.239.57` to `51.91.79.17`.
- **SNI Confirmation:** The Server Name Indication (SNI) field in the TLS ClientHello messages was `temp.sh`, confirming the intended destination.
- **TLS Version:** All sessions used **TLS 1.3**, which prevented inspection of the encrypted payload.

C.5 Data Volume Analysis

The TCP conversation data provides a precise measurement of the exfiltrated data volume. For the conversation between the internal staging host (`10.128.239.57`) and the external server (`51.91.79.17`), the analysis shows:

- **Outbound Volume (Upload): 1,082,867,712 bytes (~1,033 MB)** were sent from the internal host to the external server.
- **Inbound Volume (Responses):** Approximately 15 MB of data was received, consistent with TCP acknowledgements and server-side responses during a large upload.

The dominant data flow was outbound, confirming this was an exfiltration event, not a download.

C.6 Compromised Data Identification

While the uploads were encrypted, extensive SMB logging reveals exactly which sensitive files were accessed and staged on `10.128.239.57` immediately prior to the exfiltration. The attacker targeted and collected a wide range of high-impact data:

- **`user_db_export.json`**: Accessed at `2025-03-06T23:14:27.132Z` from file server `10.128.239.37`. This file contains extensive PII, including **names, Social Security Numbers, dates of birth, and GPS coordinates**.
- **`credit_card_transactions_2024.csv`**: Staged from `10.128.239.37`. This file contains cardholder names, full credit card numbers, expiration dates, and **CVV codes**.
- **Domain Controller Backups:** Veeam backup files for domain controllers were accessed on backup servers, including `DC1.vib` and `DC3.vib` (accessed `2025-03-06T22:00:38Z`) and `DC7.admin.vib`. These files contain copies of the Active Directory database (`NTDS.dit`) and enable offline credential harvesting.
- **Law Enforcement Archives:** At least **17** ZIP archives containing confidential FBI National Incident-Based Reporting System (NIBRS) data were staged from server `10.128.239.176`. Key files include:
- `arrestees.zip` (accessed `2025-03-06T23:11:03.956Z`)
- `offenders.zip` (accessed `2025-03-06T23:32:07.797Z`)
- `incidents.zip` (accessed `2025-03-06T23:11:28.875Z`)
- `victims.zip`
- **Group Policy Objects (GPOs):** Files were accessed from domain controllers that reveal attacker tactics:
- `Groups.xml` (accessed `2025-03-01T20:02:13.334Z`): Contains policies to add "Domain Users" to the local "Remote

C.7 Archive Compression and Staging

The attacker staged at least **28** compressed archives (`.zip` , `.7z`) from various servers onto the compromised host `10.128.239.57` before uploading them. The file server `10.128.239.37` was a primary target, with **27,305** SMB file access events recorded against it during the staging process. This hub-and-spoke collection model is efficient and typical of large-scale exfiltration operations.

C.8 Encryption and Analytical Limitations

The use of TLS 1.3 by the threat actor is a significant analytical constraint. While we can confirm with high confidence *that* data was exfiltrated, *where* it went, and *how much* was stolen, we cannot inspect the encrypted traffic to see the specific contents of each of the 11 upload sessions. The conclusions about the compromised data types are therefore based on the strong temporal correlation between the SMB staging activity and the subsequent TLS uploads. Host-based forensics on `10.128.239.57` would be required to definitively map specific files to specific archives.

D. Payload Deployment

D.1 Overview

The final phase of the attack was the deployment of the Lynx ransomware payload. This was not an automated, worm-like propagation but a deliberate, hands-on operation conducted by the attacker. Using interactive RDP sessions from the central staging hub (`10.128.239.57`), the attacker manually connected to high-value targets, transferred the ransomware executables, and executed them. The primary deployment occurred on March 9, 2025, targeting at least 6 key servers.

D.2 How the Payload was Deployed

The deployment mechanism was a combination of SMB file transfers and interactive RDP sessions.

1. **Staging:** The attacker first transferred the ransomware payloads and supporting tools to target systems via SMB, typically writing them to administrative shares (`ADMIN$` , `C$`) or software deployment shares.

2. **Execution:** The attacker then established an RDP session to the target host and manually executed the payload. This is confirmed by RDP sessions on March 9 using credentials like `it1` and `SAFETY\IT` to log into file servers and backup servers.

The host `10.128.239.57` served as the staging hub for all deployment activities.

- **DPAPI Credential Theft:** The `bkrp_BackupKey` operation on **2025-03-06T22:41:51.038Z** ensured the attacker possessed domain-wide credentials.
- **Backup System Sabotage:** Starting at **2025-03-06T23:04:53.337Z**, the attacker accessed backup repositories on servers `.39` , `.36` , and `.35` , enumerating backup files for domain controllers (`DC1` , `DC3`) and virtual machines (`WIN712` , `WIN919` , `WIN962`). This was done to identify and later target backups to hinder recovery.
- **Final Write-Access Validation:** The third `delete.me` wave on **2025-03-08T08:22:04.126Z** served as a final check of which systems were online and writable just before the main deployment.

D.4 Payload Transfer

Network evidence confirms the transfer of several malicious executables from the staging hub `10.128.239.57` to various targets.

observed, likely containing a list of target IPs.

- `Microsofts.exe` **(Secondary Payload):** A secondary payload of unknown function, also deployed during the March 6 wave.
- `UninstallWinClient.exe` **(Security Tool Remover):** At **2025-03-08T09:06:19.788Z**, this file was opened on host `10.128.239.66`. This tool is designed to disable or uninstall security products (T1562.001) to ensure the ransomware can execute without interference.
- `HOW TO BACK FILES.txt` **(Ransom Note):** The appearance of this file in SMB directory listings is the definitive indicator of successful encryption on a host.

The initial executable deployment wave on March 6 began with Suricata alerts for executable file creation on host `.36` at `23:06:23.109Z`, followed by deployment to `.34` at `23:12:37.873Z`, and a larger wave targeting `.37` starting at `23:13:49Z`.

D.5 Impact (Final Encryption)

The final, hands-on encryption phase was initiated following the attacker's return session on March 8.

- **Attacker Return Session:** At **2025-03-08T08:20:42.177Z**, attacker IP `77.90.153.30` connected via RDP to `10.128.239.57`. The session lasted approximately **67 minutes and 35 seconds**, during which 24.7 MB of data was received by the staging host, likely the final ransomware toolset.
- **Interactive Deployment:** On March 9, the attacker used RDP to connect to and encrypt key servers:
- `10.128.239.35` at `09:00:11.160Z` (cookie: `it1`)
- `10.128.239.36` at `09:11:27.379Z`
- `10.128.239.39` at `09:21:04.287Z` (cookie: `SAFETY\IT`)
- `10.128.239.37` at `09:22:49.298Z` (cookie: `IT1`)
- `10.128.239.176` at `09:29:31.040Z` (cookie: `IT1`)

The presence of the ransom note `HOW TO BACK FILES.txt` on these systems confirms that encryption was completed. The scale of the attack, based on the `delete.me` probing, potentially affects up to 135 hosts.

MITRE ATT&CK Master Mapping

TECHNIQUE	SUB-TECHNIQUE	NAME	PHASE	EVIDENCE SUMMARY
T1133	External Remote Services	Initial Access	RDP brute-force against `10.128.239.57` leading to `lgallegos` compromise.	
T1078	Valid Accounts	Initial Access	Use of compromised `lgallegos` credential for RDP and Kerberos auth.	
T1018	Remote System Discovery	Discovery	`delete.me` probing and RDP SYN scan to identify 153 live hosts.	
T1135	Network Share Discovery	Discovery	274 `NetrShareEnum` calls to map shares across 106 hosts.	
T1087	T1087.002	Domain Account	Discovery	SAMR enumeration (`SamrLookupDomainInSamServer`) to map domain accounts.

				DCs `.23` and `.29`.
T1003	OS Credential Dumping	Credential Access	`bkrp_BackupKey` call to steal domain DPAPI backup key at 2025-03-06T22:41:51Z.	
T1021	T1021.001	Remote Desktop Protocol	Lateral Movement	RDP pivots to 41 unique internal hosts, including manual deployment on March 9.
T1021	T1021.002	SMB/Windows Admin Shares	Lateral Movement	Access to `ADMIN$` on 62 hosts, including DCs in WATER, POWER, and PARKS domains.
T1560	Archive Collected Data	Collection	Staging of 28+ compressed archives (`.zip` , `.7z`) on `10.128.239.57` .	
T1039	Data from Network Shared Drive	Collection	SMB access to `user_db_export.json` , `.vib` backups, and NIBRS data from servers.	
T1567	Exfiltration Over Web Service	Exfiltration	Upload of 1,033 MB of data to `temp.sh` (51.91.79.17) over HTTPS.	
T1570	Lateral Tool Transfer	Deployment	Transfer of `kkwlo.exe` , `hfs.exe` , and `Microsofts.exe` via SMB.	
T1562	T1562.001	Impair Defenses: Disable or Modify Tools	Defense Evasion	Deployment of `UninstallWinClient.exe` to remove security software.
T1486	Data Encrypted for Impact	Impact	Deployment of Lynx ransomware (`kkwlo.exe`) and appearance of `HOW TO BACK FILES.txt` .	

Conclusion and Recommendations

This investigation details a sophisticated, multi-stage ransomware attack by the Lynx group, characterized by methodical reconnaissance, privilege escalation, data exfiltration, and manual payload deployment. The attacker successfully compromised the network via an exposed RDP server, stole domain-wide credentials, exfiltrated over 1 GB of highly sensitive data, and encrypted critical systems. The following recommendations are prioritized to contain the incident, remediate the environment, and build long-term resilience.

Critical (48–72 hours)

1. **Credential Reset:** The attacker possesses credentials and keys enabling persistent access and impersonation.

- **Business Risk:** Active attacker control of the AD environment.
- **Action:** Immediately disable the `lgallegos` , `it1` , and `SAFETY\IT` accounts. Force-reset passwords for ALL domain user and service accounts. Perform a `krbtgt` double-password reset to invalidate all existing Kerberos tickets.
- **MITRE Mitigation:** M1027 (Password Policies)

3. **Block Exfil Services:** The attacker's exfiltration channel may still be in use.
   - **Business Risk:** Continued data leakage or command-and-control communication.
   - **Action:** Implement a firewall rule to block all traffic to and from the IP address `51.91.79.17`. Create a DNS sinkhole for the domain `temp.sh` to prevent any internal hosts from resolving it.
   - **MITRE Mitigation:** M1037 (Filter Network Traffic)

High Priority (1–2 weeks)

4. **Segment Remote Access:** Flat remote access enabled the initial compromise.
   - **Action:** Deploy a Privileged Access Management (PAM) solution to vault and rotate administrative credentials. Enforce MFA on all remote access, especially for privileged accounts.
   - **MITRE Mitigation:** M1032 (Privileged Account Management)
5. **Harden Backup Systems:** Backups were directly accessible and targeted by the attacker.
   - **Action:** Isolate backup servers on a dedicated, highly restricted network segment. Ensure backups are immutable and stored offline, following the 3-2-1 rule. Remove backup servers from the primary domain.
   - **MITRE Mitigation:** M1030 (Network Segmentation), M1053 (Data Backup)
6. **Restrict SAMR/LSARPC:** The attacker heavily abused these protocols for AD enumeration.
   - **Action:** Apply the `Network access: Restrict clients allowed to make remote calls to SAM` group policy setting to prevent non-administrative workstations from enumerating domain accounts.
   - **MITRE Mitigation:** M1028 (Operating System Configuration)

Medium Priority (1–3 months)

7. **Deploy EDR on All Hosts:** The attacker was able to disable defenses.
   - **Action:** Deploy a modern Endpoint Detection and Response (EDR) solution on all servers and workstations. Ensure tamper protection is enabled and enforced to prevent tools like `UninstallWinClient.exe` from succeeding.
   - **MITRE Mitigation:** M1049 (Antivirus/Antimalware)
8. **DLP for Sensitive Files:** Highly sensitive PII, financial, and LE data was easily accessible.
   - **Action:** Implement a Data Loss Prevention (DLP) solution to classify sensitive data based on content. Create policies to monitor and block unauthorized access or transfer of files containing SSNs, credit card numbers, etc.
   - **MITRE Mitigation:** M1057 (Data Loss Prevention)
9. **Network Segmentation:** The flat internal network permitted unimpeded lateral movement.
   - **Action:** Implement micro-segmentation to create trust zones. Isolate domain controllers from the general workstation population and restrict server-to-server communication to only what is explicitly required.
   - **MITRE Mitigation:** M1030 (Network Segmentation)

Strategic (3–6 months)

10. **Zero Trust Architecture:** Assume breach and move away from a perimeter-based security model.
    - **Action:** Begin a strategic initiative to implement a Zero Trust architecture, where every access request is authenticated and authorized, regardless of whether it originates from inside or outside the network.
11. **Incident Response Retainer:** Ensure rapid access to expert support for future incidents.
    - **Action:** Establish a retainer with a qualified incident response firm to reduce response time and improve outcomes in the event of a future security breach.

2025-03-01T18:24:08.333Z	`10.128.239.57`	`10.128.239.29`	SMB	Attacker accesses SYSVOL share on WATER DC for GPO enumeration.
2025-03-01T23:25:07.989Z	`195.211.190.189`	`10.128.239.57`	RDP	Attacker establishes RDP connection to patient zero.
2025-03-01T23:25:36.515Z	`195.211.190.189`	`10.128.239.57`	RDP	Compromised credential `lgallegos` is presented.
2025-03-01T23:25:43.484Z	`10.128.239.57`	`10.128.239.23`	Kerberos	Successful domain authentication for user `lgallegos`.
2025-03-01T23:25:44.172Z	`10.128.239.57`	`10.128.239.23`	DCERPC	DRSUAPI `DRSBind` call, probing for DCSync capabilities.
2025-03-01T23:30:37.500Z	`10.128.239.57`	`multiple`	DCERPC	`NetrShareEnum` operations begin, mapping network shares.
2025-03-01T23:30:37.580Z	`10.128.239.57`	`multiple`	SMB	Wave 1 of `delete.me` write-access testing begins (449 ops).
2025-03-01T23:30:38.907Z	`10.128.239.57`	`10.128.239.29`	SMB	Authenticated access to `ADMIN$` share on WATER DC.
2025-03-01T23:30:40.965Z	`10.128.239.57`	`10.128.239.29`	DCERPC	SAMR enumeration begins with `SamrLookupDomainInSamServer`.
2025-03-02T00:20:11.897Z	`10.128.239.57`	`10.128.239.64`	RDP	First internal RDP pivot using `lgallegos` credential.
2025-03-06T20:26:28.950Z	`195.211.190.189`	`10.128.239.57`	RDP	Attacker returns to patient zero (Spamhaus DROP alert).
2025-03-06T22:41:51.038Z	`10.128.239.57`	`10.128.239.23`	DCERPC	`bkrp_BackupKey` call steals domain DPAPI backup key.
2025-03-06T22:50:28.096Z	`10.128.239.57`	`multiple`	SMB	Wave 2 of `delete.me` write-access testing begins (526 ops).
2025-03-06T23:04:53.418Z	`10.128.239.57`	`10.128.239.39`	SMB	Access to `VeeamConfigBackup` directory on backup server `.39`.
2025-03-06T23:11:03.956Z	`10.128.239.57`	`10.128.239.176`	SMB	Staging of law enforcement data: `arrestees.zip` accessed.
2025-03-06T23:12:38.259Z	`10.128.239.57`	`10.128.239.34`	SMB	Payload staging: `hfs.exe` transferred to host `.34`.
2025-03-06T23:14:27.132Z	`10.128.239.57`	`10.128.239.37`	SMB	Staging of PII data: `user_db_export.json` accessed.
2025-03-06T23:40:59.105Z	`10.128.239.57`	`10.128.239.20`	DNS	First DNS query for exfiltration domain `temp.sh`.
2025-03-06T23:41:00.000Z	`10.128.239.57`	`51.91.79.17`	TLS	Start of 1,033 MB data exfiltration upload to `temp.sh`.
2025-03-08T08:20:42.177Z	`77.90.153.30`	`10.128.239.57`	RDP	Second attacker IP returns for final deployment phase (~67 min session).

2025-03-09T09:00:11.160Z	`10.128.239.57`	`10.128.239.35`	RDP	Interactive RDP session to file server `.35` for manual ransomware deployment.
2025-03-09T09:21:04.287Z	`10.128.239.57`	`10.128.239.39`	RDP	Interactive RDP to backup server `.39` using `SAFETY\IT` credential.
2025-03-09T09:29:31.040Z	`10.128.239.57`	`10.128.239.176`	RDP	Interactive RDP to staging server `.176` for final encryption.

Appendix B: Full Indicators of Compromise

TYPE	VALUE	FIRST SEEN	LAST SEEN	CONTEXT
Attacker IP	`195.211.190.189`	2025-03-01T23:25:07Z	2025-03-06T22:41:30Z	Initial access and return session IP.
Attacker IP	`77.90.153.30`	2025-03-08T08:20:42Z	2025-03-09T08:54:26Z	Payload deployment session IP.
Exfil IP	`51.91.79.17`	2025-03-06T23:40:59Z	2025-03-06T23:42:18Z	Destination for 1,033 MB data exfiltration.
Domain	`temp.sh`	2025-03-06T23:40:59Z	2025-03-06T23:42:18Z	Exfiltration service domain.
Credential	`lgallegos`	2025-03-01T23:25:36Z	2025-03-02T00:20:11Z	Initial compromised domain account.
Credential	`it1`	2025-03-09T09:00:11Z	2025-03-09T09:29:31Z	Credential used for RDP deployment on March 9.
Credential	`SAFETY\IT`	2025-03-09T09:21:04Z	2025-03-09T09:21:04Z	Cross-domain credential used for RDP deployment.
File Name	`kkwlo.exe`	2025-03-06T23:06:23Z	2025-03-09T09:29:31Z	Primary Lynx ransomware payload.
File Name	`hfs.exe`	2025-03-06T23:12:38Z	2025-03-06T23:12:38Z	HTTP File Server used for lateral payload distribution.
File Name	`Microsofts.exe`	2025-03-06T23:06:23Z	2025-03-06T23:13:49Z	Secondary payload.
File Name	`UninstallWinClient.exe`	2025-03-08T09:06:19Z	2025-03-08T09:06:19Z	Security tool remover.
File Name	`HOW TO BACK FILES.txt`	2025-03-09T09:00:11Z	2025-03-09T09:29:31Z	Lynx ransomware note.
File Name	`delete.me`	2025-03-01T23:30:37Z	2025-03-08T08:22:28Z	File used for write-access testing.
Internal Host	`10.128.239.57`	2025-03-01T18:20:01Z	2025-03-09T09:29:31Z	Patient Zero / Attacker Staging Hub.
Internal Host	`10.128.239.23`	2025-03-01T23:25:43Z	2025-03-06T22:41:51Z	Domain Controller (WATER), target of DPAPI theft.

Internal Host	`10.128.239.176`	2025-03-06T23:11:03Z	2025-03-09T09:29:31Z	Staging server containing law enforcement data.
Internal Host	`10.128.239.39`	2025-03-06T23:04:53Z	2025-03-09T09:21:04Z	Backup server targeted for sabotage/encryption.
Internal Host	`10.128.239.36`	2025-03-06T23:05:55Z	2025-03-09T09:11:27Z	Backup server targeted for sabotage/encryption.